

The organization relies on limited leveraged Azure services; thus the primary threat vector is a compromised Windows VM being used to move laterally between Azure and the on-premises environment.

Tool-Specific TARA Gaps & Custom Configuration Checks

The matrix below outlines the critical threat vectors to address, identifying specific gaps left by CIS Benchmarks and providing the exact configuration steps required for the stack.

Threat Vector / Domain	What CIS Benchmarks Overlook	How to Enforce Using the Tool Stack
Privileged Access & Pivot Control	Checks local Windows account names and password complexity.	BeyondTrust + SentinelOne: Enforce a baseline check that all local administrative sessions use BeyondTrust Privileged Remote Access (PRA) and are recorded. Alert via SentinelOne if a local cmd.exe or PowerShell.exe process executes with high privileges without an active BeyondTrust session token.
Pipeline-to-IaaS Vulnerabilities	Only checks standard Windows update schedules.	Snyk + Rapid7 / Tenable.io: Snyk must scan HashiCorp Terraform (.tf) templates for misconfigured NSGs before deployment. Once live, use Tenable/Rapid7 to verify that Windows VMs running proprietary financial software do not contain vulnerable open-source dependencies hidden within compiled third-party binaries. Correlate asset records using the Azure Virtual Machine Unique ID (vmId) as the primary key.
SASE / Egress Traffic Deviations	Assumes firewall rules are static and correct.	Cisco SASE + SentinelOne: Set a baseline check that blocks all Windows VMs from using custom DNS or alternate routing tables. Cisco SASE should drop all outbound traffic originating from Azure VMs that does not clear through the Secure Web Gateway (SWG), matching it against SentinelOne network isolation telemetry.

Automated Incident Isolation	Focuses on single-system log generation.	Tines SOAR: Validate automated workflows. If SentinelOne flags an active credential dumping attempt (e.g., lsass.exe manipulation) on a Windows VM, Tines must instantly trigger an NSG rule update to isolate the asset from the on-premises express route.
Financial Engineering Phishing Paths	Checks standard Outlook/Office local trust configurations.	KnowBe4 + Tines: Build an active TARA simulation for quantitative and financial analysts. If a user fails a highly targeted KnowBe4 "vishing" or spear-phishing simulation, Tines must automatically trigger a temporary, restrictive BeyondTrust policy that limits local administrative access onto corporate infrastructure.

2. Implement the Tool-Enforced TARA Plan

[1. Snky/IaC Guardrails] → [2. SASE & SentinelOne Edge] → [3. BeyondTrust Tiering] → [4. Tines Loop Validation]

Step 1: Establish Infrastructure-as-Code (IaC) Guardrails

- **Check:** Evaluate deployment pipelines for Windows virtual machines.
- **TARA Risk Verification:** Use Snky to programmatically scan HashiCorp Terraform (.tf) code structures within the CI/CD pipeline. Block any deployment pipeline that builds a Windows VM with the Azure Serial Console enabled for all users or leaves the local Instance Metadata Service (IMDS) unprotected against unprivileged application profiles.

Step 2: Correlate Network Perimeters with Endpoint Activity

- **Check:** Monitor how the hybrid network handles egress communication.
- **TARA Risk Verification:** Use Cisco SASE to ensure that critical banking servers cannot connect directly to public package repositories or rogue endpoints. If an unauthorized egress attempt is logged, configure SentinelOne to perform an immediate differential memory dump of the active Windows system to check for in-memory malware or beaconing activity. Exfiltrate the captured memory dump directly to the dedicated, network-isolated Azure Blob Storage Container secured via customer-managed keys (CMK) and private endpoints.

Step 3: Enforce Rigid Privileged Access Tiering

- **Check:** Review how local administrators log into both Azure IaaS and on-premises environments.
- **TARA Risk Verification:** Route all administrative access through BeyondTrust. Ensure that local infrastructure administrators cannot use the same credentials to log into Windows VMs hosted in Azure as they use for on-premises systems. This approach breaks the active lateral movement pathway between cloud and on-premises environments.

Step 4: Validate Automated SOAR Workflows

- **Check:** Ensure automated incident response playbooks function as intended.
- **TARA Risk Verification:** Use Tines to run scheduled, simulated alert validation loops. Ensure that when Tenable.io or Rapid7 identifies a critical exploit (such as an unpatched remote code execution vulnerability) on a live, internet-facing transaction server, Tines automatically initiates micro-segmentation via Cisco SASE until the system is fully remediated.

3. Critical Gaps to Monitor in the Multi-Vendor Security Stack

- **Tool Telemetry Desynchronization:** With both Tenable.io and Rapid7 in use, there is a risk of visibility gaps if asset groups are split across platforms. The Tines architecture must ingest payloads from both scanners, using the persistent Azure Virtual Machine Unique ID (vmId) as the core asset deduplication identifier to ensure unmanaged Windows VMs do not drop off the active scanning radar.
- **Credential Exposure via Endpoint Agents:** Security tools like SentinelOne, BeyondTrust, and Cisco SASE run with the highest possible system privileges (NT AUTHORITY\SYSTEM). The TARA baseline must explicitly verify that the local configurations, log files, and debugging modes of these agents do not inadvertently expose API keys, tenant tokens, or temporary system passwords in plaintext.